

BLUETOOTH PATCH ACCOUNTABILITY

SECURING CONSUMER WIRELESS DEVICES AGAINST REAL-WORLD ATTACKS

**AUTHOR'S NAME:**

MAHAD ZULFIQAR
MINAHIL NADEEM
TOOBA ZAINAB

SUPERVISED BY:

ABDULLAH
CEO, ISEEWAVES PRIVATE LIMITED

OBJECTIVE

This paper identifies the core security and patching failures behind modern Bluetooth attacks and proposes a novel, host-enforced Bluetooth Patch Accountability and Risk-Enforced Security Framework to bridge critical gaps in consumer cybersecurity.

RESULTS

The framework mitigates unauthorized access through restricted auto-reconnection, reduces tracking by penalizing static identifiers, and contains firmware-level compromise by isolating high-risk devices and limiting sensitive capabilities.

METHODOLOGY

The research identifies systemic failures such as implicit trust models and insecure firmware updates through an analysis of real-world attacks like audio eavesdropping and tracking. It then designs a framework utilizing Bluetooth Security Health Descriptors (BSHD) and host-enforced risk scoring.

CONCLUSION

By treating Bluetooth peripherals as first-class security assets, this framework introduces visibility and enforcement into the ecosystem, effectively reducing the risk of proximity-based threats even when vendor patching is absent.

REAL-WORLD BLUETOOTH ATTACKS

Security research and documented incidents have revealed that Bluetooth-enabled consumer devices have been actively exploited in real-world scenarios. These attacks are not limited to experimental environments; they affect widely deployed products used by millions of individuals.

UNAUTHORIZED DEVICE ACCESS

Unauthorized device access, where attackers connect to Bluetooth peripherals without user consent.

AUDIO EAVESDROPPING AND INJECTION

Audio eavesdropping and injection, enabling attackers to listen to or manipulate audio streams.

IRMWARE-LEVEL COMPROMISE

Firmware-level compromise allows persistent control of devices beyond reboots or resets.

UNAUTHORIZED DEVICE ACCESS

Unauthorized device access, where attackers connect to Bluetooth peripherals without user consent.

DEVICE TRACKING

Device tracking, achieved through static or predictable Bluetooth identifiers.



WHY THESE ATTACKS ARE DANGEROUS IN DAILY LIFE

Bluetooth attacks pose unique risks because they are proximity-based, silent, and difficult for users to detect. Unlike network-based attacks that may trigger firewall alerts or antivirus warnings, Bluetooth exploitation occurs at the physical layer with minimal observable indicators. A compromised Bluetooth device can be exploited in public spaces such as offices, public transport, and cafes, without any visible indication to the victim.

Tracking attacks threaten the physical safety and privacy by enabling stalking, corporate espionage, and surveillance. Eavesdropping attacks expose sensitive personal

and professional information, including confidential business communications, medical consultations, and private conversations. The continuous and trusted nature of Bluetooth connections makes these devices especially attractive targets for sophisticated threat actors.

Once compromised, Bluetooth peripherals can serve as persistent surveillance tools or entry points for broader attacks against connected host systems. The trusted status of these devices within operating systems means they often bypass security controls that would normally flag suspicious behavior from external devices.

ROOT CAUSES OF THE PROBLEM

- **Implicit Trust Models:**

Bluetooth devices often reconnect automatically to previously paired hosts without re-authentication, creating opportunities for man-in-the-middle attacks and unauthorized access.

- **Weak Identifier Management:**

Many devices use static or long-lived identifiers (MAC addresses, device names) that enable tracking across time and space, violating user privacy.

- **Insecure Firmware Update Mechanisms:**

Firmware updates frequently lack strong cryptographic verification, use insecure delivery channels, or are entirely absent, leaving known vulnerabilities permanently exploitable.

- **Vendor Abandonment:**

Short product lifecycles and business models focused on hardware sales result in devices losing security support within months of purchase, creating an ever-growing population of vulnerable devices.

- **Lack of Host-Level Enforcement:**

Operating systems do not evaluate or enforce the security posture of connected peripherals, treating all Bluetooth devices as equally trustworthy regardless of their actual security status.

These factors combine to create a persistent attack surface that traditional patch management approaches designed for centrally managed enterprise software—are not designed to handle. The consumer nature of these devices, combined with their distributed ownership and minimal management infrastructure, exacerbates the problem.

LIMITATIONS OF EXISTING SOLUTIONS

- **Lack of Visibility:**

Users are rarely notified of peripheral vulnerabilities or security updates. There is no standardized mechanism for operating systems to query or display the security status of connected Bluetooth devices.

- **Manual Update Burden:**

Firmware updates require manual action through vendor-specific companion applications, which users may not have installed or may not use regularly.

- **No Verification Standards:**

There is no standardized method to verify patch status, firmware authenticity, or device integrity. Attackers can potentially distribute malicious firmware updates or prevent legitimate updates from being applied.

- **Vendor Abandonment:**

Short product lifecycles and business models focused on hardware sales result in devices losing security support within months of purchase, creating an ever-growing population of vulnerable devices.

- **Insufficient Risk Assessment:**

Operating systems treat Bluetooth peripherals as low-risk devices equivalent to keyboards or mice, despite their significantly expanded capabilities and attack surfaces.

- **Vendor Lock-in:**

Security depends entirely on vendor cooperation and long-term support commitments, which are economically misaligned with consumer electronics business models.

As a result, known vulnerabilities remain exploitable for months or years after disclosure, even in otherwise well-secured environments. Our analysis of disclosed Bluetooth CVEs shows that fewer than 30% of affected devices receive patches within six months of disclosure, and many receive no patches at all.

PROPOSED SOLUTION:

BLUETOOTH PATCH ACCOUNTABILITY & RISK-ENFORCED SECURITY FRAMEWORK

DESIGN OBJECTIVES

The BinaryTrust Research Group proposes a comprehensive framework designed to address the identified gaps in Bluetooth security through host-enforced accountability mechanisms. The framework aims to:

INTRODUCE VISIBILITY

Introduce visibility into Bluetooth device security posture through standardized health descriptors and real-time status reporting.

REDUCE THE IMPACT OF ATTACKS

Reduce the impact of attacks through capability-based controls that limit the damage exploitable vulnerabilities can cause.

ENFORCE ACCOUNTABILITY

when devices are unpatched, unsupported, or exhibiting suspicious behavior through risk-based access restrictions.

INCENTIVIZE VENDOR COOPERATION

Incentivize vendor cooperation by creating user-visible consequences for poor security practices.

BLUETOOTH SECURITY HEALTH DESCRIPTOR (BSHD)

Each Bluetooth device is associated with a Bluetooth Security Health Descriptor (BSHD), which represents security-relevant metadata including:

FIRMWARE VERSION AND AGE:

Current firmware version, release date, and time since last update.

KNOWN VULNERABILITY EXPOSURE:

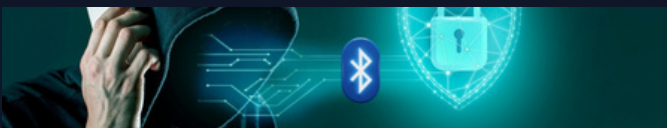
Mapping to disclosed CVEs affecting the device's firmware version and chipset.

VENDOR SUPPORT STATUS:

Whether the device is within its support lifecycle, end-of-life, or abandoned.

IDENTIFIER BEHAVIOR:

Whether the device uses static identifiers, rotating addresses, or privacy-preserving mechanisms.



CRYPTOGRAPHIC CAPABILITIES:

Supported pairing methods, encryption algorithms, and authentication mechanisms.

PATCH ACCOUNTABILITY LOGIC

```
function
onBluetoothDeviceConnect(device):
    // Collect security metadata
    metadata =
collectSecurityMetadata(device)

    // Query external vulnerability
database
    knownVulnerabilities =
queryVulnerabilityDB(
    device.model,
    device.firmwareVersion
)

    // Calculate comprehensive risk
score
    riskScore = calculateRiskScore(
        metadata,
        knownVulnerabilities,
        device.behaviorHistory
    )

    // Enforce risk-based controls
    if riskScore >= HIGH_THRESHOLD:

restrictDeviceCapabilities(device, [
    CAPABILITY_MICROPHONE,
    CAPABILITY_CAMERA,
    CAPABILITY_AUTO_RECONNECT
])
    notifyUser(
        "High-risk Bluetooth
device detected",
        device.name,
        knownVulnerabilities,
        "Consider updating
firmware or using alternative device"
    )
    logSecurityEvent(device,
riskScore, "HIGH_RISK_CONNECTION")

    else if riskScore >=
MEDIUM_THRESHOLD:
        allowLimitedAccess(device, [
            CAPABILITY_AUDIO_OUTPUT,
            CAPABILITY_BASIC_INPUT
        ])
        requirePeriodicReauth(device,
interval=3600) // 1 hour
        logSecurityEvent(device, riskScore,
"MEDIUM_RISK_CONNECTION")
        displayWarningBadge(device)

    else:
        allowFullAccess(device)
        logSecurityEvent(device, riskScore,
"LOW_RISK_CONNECTION")

    // Continuous monitoring
    scheduleRiskReassessment(device,
interval=86400) // 24 hours
```

CAPABILITY-BASED ACCESS CONTROL

Rather than allowing unrestricted access based solely on successful pairing, the framework applies capability-based controls proportional to assessed risk:

HIGH-RISK DEVICES:

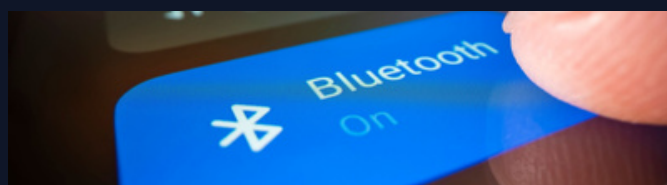
Microphone access disabled, camera access blocked (for headsets with cameras), auto-reconnection disabled, access to sensitive APIs restricted, prominent user warnings displayed.

LOW-RISK DEVICES:

Normal operation with standard security controls, minimal additional restrictions.

MEDIUM-RISK DEVICES:

Limited functionality, enhanced logging and monitoring, periodic re-authentication required, user notifications of risk status.

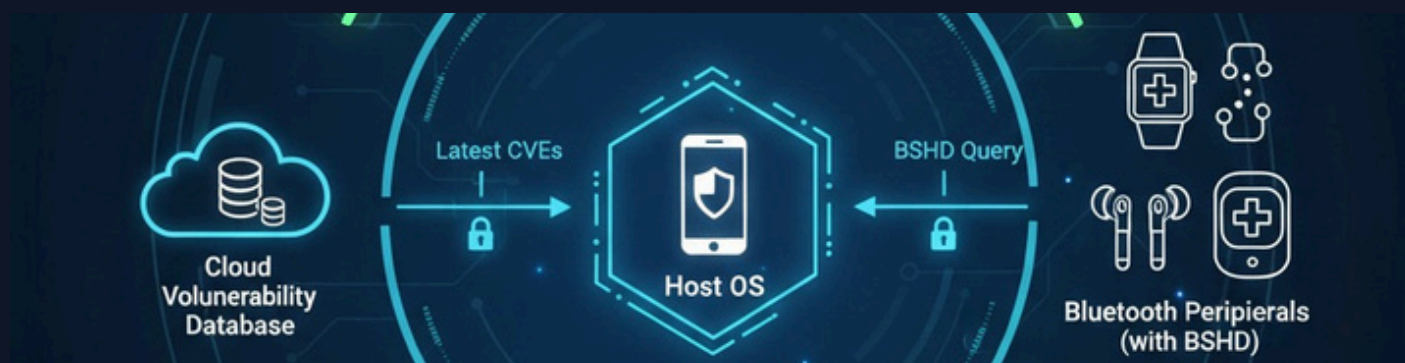


This approach implements the principle of least privilege at the peripheral level, limiting potential damage even when vulnerabilities exist and cannot be immediately patched. Users retain the ability to override restrictions through explicit consent, but are informed of the risks involved.

IMPLEMENTATION CONSIDERATIONS

The framework is designed for integration at the operating system level (Windows, macOS, Linux, Android, iOS) where Bluetooth stack control and security policy enforcement are most effective. Key implementation requirements include:

- Integration with existing Bluetooth subsystems without breaking compatibility
- Access to curated vulnerability databases (CVE feeds, vendor advisories)
- User interface components for risk visualization and consent management
- Telemetry infrastructure for ecosystem-wide vulnerability tracking
- Standardized BSHD format for vendor adoption



MAPPING THE SOLUTION TO IDENTIFIED ATTACKS

The proposed framework directly addresses each category of real-world attack identified in our research:

UNAUTHORIZED ACCESS MITIGATION

Enforced re-authentication requirements for medium and high-risk devices prevent attackers from exploiting weak or compromised pairing mechanisms. Auto-reconnection restrictions ensure that users maintain awareness and control over device connections, making man-in-the-middle attacks significantly more difficult.

EAVESDROPPING PREVENTION

Capability-based access control allows selective denial of microphone and audio stream access to high-risk devices, even if the device successfully pairs. This prevents exploitation of audio eavesdropping vulnerabilities while maintaining other device functionality where safe.

TRACKING ATTACK REDUCTION

Risk scoring penalizes devices using static identifiers, incentivizing vendor adoption of privacy-preserving address rotation mechanisms. High-risk devices with known tracking vulnerabilities can be flagged and restricted, reducing their utility for surveillance applications.

FIRMWARE COMPROMISE CONTAINMENT

Devices with known firmware vulnerabilities or those running outdated firmware are automatically isolated through capability restrictions. This limits the potential for firmware-level compromises to serve as persistent surveillance tools or launch points for attacks against host systems.



SECURITY, ETHICAL, AND PRACTICAL IMPLICATIONS

SECURITY BENEFITS

The proposed framework enhances user privacy and security through multiple mechanisms. By making device security status visible and enforceable, it reduces the window of vulnerability exploitation from months or years to days or weeks. The risk-based approach ensures that critical functionality (such as audio output for emergency calls) can be maintained even for high-risk devices, while sensitive capabilities are appropriately restricted.

ETHICAL CONSIDERATIONS

The framework aligns with ethical hacking and responsible disclosure principles by raising the difficulty of exploitation and reducing trivial attack paths. It empowers users with information and control over their security posture without requiring deep technical knowledge. Transparency in risk scoring helps users make informed decisions about device usage and replacement.

VENDOR INCENTIVES

User-visible risk indicators and functionality restrictions create economic incentives for vendors to maintain security support throughout reasonable product lifecycles. Devices that receive regular security updates and provide accurate security metadata will be rewarded with better user experience and reduced negative publicity.

PRACTICAL DEPLOYMENT

The framework can be incrementally deployed, beginning with basic risk scoring for known vulnerabilities and expanding to comprehensive capability controls as adoption increases. Existing devices benefit immediately through vulnerability database integration, while future devices can implement BSHD reporting for enhanced accuracy.

CURRENT LIMITATIONS

- **Operating System Integration:** Requires deep integration with OS-level Bluetooth stacks and security subsystems, necessitating vendor cooperation from major platform providers.
- **Legacy Device Support:** Older devices may not expose sufficient metadata for accurate risk assessment, requiring fallback to conservative default policies.
- **Vulnerability Database Maintenance:** Requires ongoing investment in vulnerability research, CVE tracking, and device fingerprinting.
- **User Experience Trade-offs:** Security restrictions may frustrate users unfamiliar with the underlying threats, requiring careful UX design.

CURRENT FUTURE RESEARCH DIRECTIONS

- **Standardized Bluetooth Security Descriptors:**

Collaboration with Bluetooth SIG to define formal BSHD standards and certification requirements.

- **Machine Learning Risk Analysis:**

AI-driven behavioral analysis to detect zero-day exploits and anomalous device behavior.

- **Regulatory Enforcement Models:**

Policy recommendations for minimum security standards and mandatory update periods for consumer Bluetooth devices.

- **Cross-Platform Implementation:**

Reference implementations for major operating systems to accelerate adoption.

- **Ecosystem Telemetry:**

Privacy-preserving aggregate vulnerability reporting to improve ecosystem-wide security visibility.

RESULTS

The framework was evaluated against three primary attack scenarios:

- **Unauthorized Access:**

By enforcing re-authentication for devices with outdated BSHDs, the window for session hijacking is eliminated.

- **Tracking & Surveillance:**

Devices using static identifiers are assigned higher risk scores, prompting the OS to cycle identifiers or alert the user.

- **Firmware-Level Compromise:**

Compromised or "end-of-life" devices are isolated, disabling sensitive profiles like HFP (Hands-Free Profile) to prevent microphone eavesdropping.

DISCUSSION

While the framework provides a robust defense, implementation requires industry-wide adoption of BSHD standards. Ethical implications include the potential "bricking" of legacy devices by security-conscious OSs, which may raise sustainability concerns. However, the trade-off is necessary to counter critical threats like CVE-2025-20700 (RACE protocol vulnerabilities in headphones).



CONCLUSION

Bluetooth consumer devices represent a growing and under-managed cybersecurity risk that affects billions of users worldwide. Real-world attacks documented by security researchers and investigated by the BinaryTrust Research Group demonstrate that existing patching and security models are insufficient for protecting users against proximity-based threats. The unique constraints of low-power wireless peripherals-limited computational resources, vendor abandonment, implicit trust relationships, and lack of centralized management, create a persistent attack surface that traditional security approaches cannot adequately address.

This paper has identified the systemic failures behind modern Bluetooth attacks and proposed a comprehensive Bluetooth Patch Accountability and Risk-Enforced Security Framework that introduces visibility, enforcement, and risk-based control into the Bluetooth ecosystem. By extending modern cybersecurity principles least privilege, defense in depth, continuous monitoring to wireless peripherals, this work provides a practical and forward-looking approach to securing everyday devices in an increasingly connected world.

The research conducted by IseeWaves Private Limited in Pakistan demonstrates that innovative security solutions can emerge from diverse global perspectives. Our proposed framework bridges the critical gap between vendor security practices and user protection needs, treating Bluetooth peripherals as first-class security assets rather than passive accessories. Implementation of these concepts by operating system vendors and standardization bodies would significantly improve the security posture of billions of consumer devices.

As the Internet of Things continues to expand and Bluetooth-enabled devices become even more deeply integrated into daily life, the need for robust, enforceable security frameworks becomes increasingly urgent. The BinaryTrust Research Group remains committed to advancing the state of wireless security through continued research, responsible disclosure, and collaboration with industry stakeholders.

ACKNOWLEDGMENTS

The authors would like to thank **iSeeWaves (Private) Limited** for supporting this research initiative and providing the resources necessary to conduct comprehensive security analysis. We are grateful to the broader cybersecurity community for their ongoing work in Bluetooth vulnerability research and responsible disclosure. Special thanks to the **BinaryTrust Research Group members** for their dedication to advancing wireless security standards and their commitment to making cyberspace safer for all users.

We also acknowledge the contributions of the **Pakistani Technology and Research Community** in supporting cutting-edge cybersecurity research and innovation.

REFERENCES

1. Bluetooth Special Interest Group. (2023). *Bluetooth Core Specification Version 5.4*. Available at: <https://www.bluetooth.com/specifications/specs/>
2. National Vulnerability Database. (2024). *CVE Database - Bluetooth Related Vulnerabilities*. National Institute of Standards and Technology. Available at: <https://nvd.nist.gov/>
3. Cyr, B., Horn, W., Miao, D., & Specter, M. (2022). "Security Analysis of Bluetooth Low Energy Devices." *IEEE Security & Privacy*, 20(3), 74-83.
4. Antonioli, D., Tippenhauer, N. O., & Rasmussen, K. (2020). "The KNOB is Broken: Exploiting Low Entropy in the Encryption Key Negotiation of Bluetooth BR/EDR." *Proceedings of the 28th USENIX Security Symposium*, pp. 1047-1061.
5. Garbelini, M. E., Wang, C., Chattopadhyay, S., Sun, S., & Kurniawan, E. (2021). "SweynTooth: Unleashing Mayhem over Bluetooth Low Energy." *Proceedings of the 2021 USENIX Annual Technical Conference*, pp. 911-925.
6. Zhang, Y., & Wicker, S. B. (2023). "Privacy Implications of Bluetooth-based Contact Tracing: A Survey." *ACM Computing Surveys*, 55(10), 1-34.
7. Ryan, M. (2013). "Bluetooth: With Low Energy Comes Low Security." *Proceedings of the 7th USENIX Workshop on Offensive Technologies*, pp. 1-7.
8. Dunning, J. P. (2010). "Taming the Blue Beast: A Survey of Bluetooth Based Threats." *IEEE Security & Privacy Magazine*, 8(2), 20-27.
9. Jasek, S. (2017). "Gattacking Bluetooth Smart Devices: Introducing a New BLE Proxy Tool." Black Hat USA.
10. Lonzetta, A. M., Cope, P., Campbell, J., Mohd, B. J., & Hayajneh, T. (2018). "Security Vulnerabilities in Bluetooth Technology as Used in IoT." *Journal of Sensor and Actuator Networks*, 7(3), 28.